

Chapitre 2

L'identification des risques

Feuille d'exercices

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Exercices du chapitre

Exercice 1 — Identification descendante et ascendante, et leurs outils

- (a) Le cours définit l'identification « descendante » (top-down) comme partant « du conseil d'administration et de la direction générale pour repérer les menaces majeures susceptibles de compromettre les objectifs stratégiques de l'établissement », et l'identification « ascendante » (bottom-up) comme partant « du terrain — départements, processus, activités — pour évaluer le risque opérationnel au plus près de son origine ». Le cours précise que leur mise en regard, souvent appelée « réconciliation », « est en réalité davantage une consolidation qu'une véritable réconciliation ». Expliquer, à partir de l'exemple de la néobanque cité par le cours (cyberattaque identifiée au niveau stratégique contre vulnérabilité du système de candidature en ligne des cartes de crédit aux petites entreprises identifiée au niveau de l'unité), pourquoi il s'agit bien d'une consolidation de deux perspectives complémentaires plutôt que d'une réconciliation au sens strict d'un rapprochement de deux mesures d'un même objet.
- (b) Le cours présente la « roue des risques » comme un « outil classique de brainstorming qui aide à visualiser les interconnexions entre thèmes de risque sous forme circulaire », utile pour repérer des « chaînes de causes à effets », et illustre ce point par l'exemple d'« une pénurie de main-d'œuvre entraînant des retards de projets informatiques, qui eux-mêmes fragilisent la continuité d'activité ». Expliquer en quoi cet exemple illustre précisément une chaîne causale à trois maillons, puis expliquer le rôle complémentaire que joue le PESTLE dans le « balayage de l'horizon » pour repérer les risques émergents, en le distinguant de la roue des risques par son objet propre.
- (c) Distinguer précisément, parmi les outils d'identification ascendante, la RCSA de la cartographie des processus, à partir de leur méthode respective (« exercice mené en atelier » contre décomposition « étape par étape ») et de ce que chacune produit. Définir ensuite le « quasi-incident » (near miss) tel que le cours le caractérise, et expliquer pourquoi le cours affirme que sa remontée « n'est possible que dans un environnement de culture du risque sain, sans blâme injustifié », faute de quoi « la tentation de les dissimuler [...] devient trop forte ».
- (d) Le cours cite trois sources externes de veille des risques émergents : le Rapport sur les risques mondiaux du Forum économique mondial, l'enquête annuelle « Top Operational Risks » de risk.net, et le rapport « Operational Risk Horizon » d'ORX. Le cours précise que ces sources « ne dispensent pas d'une identification propre à l'exposition et à la vulnérabilité spécifiques de chaque organisation ». Pourquoi une organisation ne peut-elle pas se contenter de reprendre telles quelles les menaces identifiées par ces sources externes, alors même qu'elles couvrent l'ensemble du secteur ?

Exercice 2 — L'analyse de scénarios

- (a) Le cours définit l'analyse de scénarios comme l'identification « d'événements extrêmement dommageables, rares soit par nature (catastrophes naturelles, pandémies), soit par construction (cyberattaques majeures, rares parce que de nombreux contrôles devraient échouer simultanément pour qu'elles se produisent) ». Expliquer précisément la différence entre ces deux sources de rareté : en quel sens une catastrophe naturelle est-elle rare « par nature », tandis qu'une cyberattaque majeure ne l'est que « par construction », c'est-à-dire du fait de l'architecture des contrôles de l'organisation plutôt que d'une propriété intrinsèque de l'événement ?
- (b) Distinguer la phase de « génération » de la phase de « sélection » de l'exercice d'analyse de scénarios, en précisant les quatre types d'intrants qui nourrissent la première selon le cours, et l'objectif de la seconde. Le cours indique une taille de liste finale « généralement 15 à 20 scénarios pour un établissement de taille moyenne, jusqu'à 50 pour une banque internationale » : que révèle cette différence d'échelle sur la relation entre la taille et la complexité d'un établissement et l'ampleur de l'exercice d'analyse de scénarios qu'il doit conduire ?
- (c) Décrire le principe du « vote silencieux » tel que défini par le cours, en précisant à quel moment

de l'atelier il intervient et quel biais de groupe il vise spécifiquement à corriger. Pourquoi le cours précise-t-il que chaque préoccupation est « ensuite débattue une à une », plutôt que simplement collectée et classée sans discussion ?

- (d) Le cours identifie deux biais fréquents à corriger dans l'analyse de scénarios : le biais de « myopie », illustré par le constat que « les risques pandémiques, absents des registres de risques en 2019, étaient omniprésents en 2021 », et le biais de « focalisation excessive sur les causes externes », alors qu'« une part substantielle des pertes historiques majeures du secteur financier résulte en réalité de causes internes — trading non autorisé, manipulation de taux, manquements de conformité ». Expliquer pourquoi ces deux biais, bien que distincts, peuvent se renforcer mutuellement lors d'un atelier de génération de scénarios organisé peu après un événement externe marquant.

Exercice 3 — Taxonomie et inventaire des risques

- (a) Le cours affirme que « la bonne pratique du secteur financier consiste à catégoriser séparément les causes, les risques (événements), les impacts et les contrôles, puis à les relier entre eux lors de la phase d'évaluation », ajoutant que cette distinction « est souvent une question de jugement : un même incident peut être décrit avec plusieurs causes et impacts possibles selon l'angle retenu ». Construire un exemple original d'incident opérationnel et montrer, pour cet exemple, comment il peut être décrit avec au moins deux causes possibles et au moins deux impacts possibles selon l'angle retenu.
- (b) Le cours distingue trois niveaux dans la taxonomie du BCBS : « le niveau 1 (les sept catégories d'événements présentées à l'introduction), le niveau 2 (subdivisions plus fines) et le niveau 3 (exemples illustratifs) », en précisant que « seuls les deux premiers niveaux constituent des catégories réglementaires officielles ; le niveau 3 sert uniquement d'illustration ». Pourquoi le régulateur a-t-il choisi de ne pas conférer de statut réglementaire officiel au niveau 3, alors même que ce niveau est le plus proche des incidents réels observés par un établissement ?
- (c) Le cours indique qu'ORX a publié, avec Oliver Wyman, une taxonomie de référence des causes organisée selon les quatre catégories du sigle PPSE « issu de la définition de Bâle » : personnes, processus, systèmes, événements externes. Le cours distingue par ailleurs quatre catégories communes d'impacts (« la perte financière, l'atteinte à la réputation, la non-conformité réglementaire, et le préjudice client »), et une cinquième, « la perturbation du service », réservée aux « activités où la continuité de service est cruciale ». Pourquoi cette cinquième catégorie d'impact n'est-elle pas universelle, mais réservée à certaines activités seulement, et pourquoi le cours anticipe-t-il qu'elle est « appelée à se généraliser avec l'attention réglementaire croissante portée à la résilience » ?
- (d) Nommer et définir précisément les quatre types de contrôles internes distingués par le cours (préventifs, détectifs, correctifs, directifs). Définir ensuite, en les distinguant précisément les uns des autres, les quatre notions suivantes évoquées par le cours à propos de l'inventaire des risques : l'« inventaire » (ou univers des risques), le « registre des risques », les « risques émergents », et le « top-dix » des risques.

2 Exercice cumulatif (chapitre 2, chapitre 1, introduction)

Exercice 4 — L'identification des risques à la lumière du chapitre 1 et de l'introduction

- (a) Le chapitre 1 attribue à la « première ligne de défense — les propriétaires du risque » — la responsabilité « de l'identification, de l'évaluation et de la maîtrise quotidienne des risques inhérents à son activité », tandis que la « deuxième ligne », la fonction indépendante de gestion du risque opérationnel (CORF), est « chargée de développer le cadre de gestion des risques et d'exercer une supervision et un rôle de challenge sur la première ligne ». Ce chapitre définit l'identification ascendante comme partant « du terrain — départements, processus, activités —

pour évaluer le risque opérationnel au plus près de son origine », au moyen notamment de la RCSA, « exercice mené en atelier, où les participants réfléchissent collectivement aux risques et contrôles de leur activité ». Montrer que l'identification ascendante et la RCSA de ce chapitre sont l'application concrète, au niveau opérationnel, de la responsabilité d'identification attribuée à la première ligne par le chapitre 1. Qu'apporte alors la deuxième ligne, avec son rôle de « supervision et [de] challenge », à un dispositif d'identification ascendante qui resterait sinon confié à la seule première ligne ? Et pourquoi l'identification descendante de ce chapitre, qui part « du conseil d'administration et de la direction générale », relève-t-elle en revanche du sommet de la pyramide de comités décrite au chapitre 1 plutôt que de la première ligne ?

- (b) Ce chapitre affirme que la remontée des quasi-incidents « n'est possible que dans un environnement de culture du risque sain, sans blâme injustifié, faute de quoi la tentation de les dissimuler [...] devient trop forte ». Le chapitre 1 définit précisément une telle culture : « une culture du *pas de blâme injustifié* ("no unnecessary blame") encourage la remontée spontanée des incidents et des quasi-incidents, sans crainte de sanction disproportionnée pour celui qui les signale », et cite parmi les six questions typiques d'un examen prudentiel « l'exhaustivité des rapports d'incidents (y compris les quasi-incidents) ». Montrer que ces trois passages décrivent un seul et même mécanisme observé sous trois angles différents : le mécanisme comportemental (ce chapitre), sa condition culturelle préalable (chapitre 1), et son test de conformité prudentielle (chapitre 1). Si la culture no-blame venait à manquer dans un établissement, quel effet précis cela aurait-il sur l'inventaire des risques défini par ce chapitre comme « la liste exhaustive des risques auxquels l'organisation estime être exposée » — en quel sens cet inventaire cesserait-il d'être exhaustif, et de quel type de risque en particulier ?
- (c) Ce chapitre situe le niveau 1 de la taxonomie du BCBS comme « les sept catégories d'événements présentées à l'introduction ». Nommer précisément, à partir de l'introduction, ces sept catégories, et rappeler que l'introduction indique que deux d'entre elles seulement — « clients/produits/pratiques commerciales, et exécution/livraison/gestion des processus » — expliquent « 79 % de la sévérité totale » des pertes du secteur, l'introduction illustrant par ailleurs une perte de cause interne majeure avec le cas de « Jérôme Kerviel [qui] a généré 4,9 milliards d'euros de pertes de trading non autorisé chez Société Générale en 2008 ». Ce chapitre met en garde contre le « biais de focalisation excessive sur les causes externes », alors qu'« une part substantielle des pertes historiques majeures du secteur financier résulte en réalité de causes internes ». Montrer, en s'appuyant précisément sur le cas Kerviel rapporté par l'introduction, comment un atelier de génération de scénarios qui négligerait de puiser dans les pertes internes de cette nature — pourtant l'un des quatre intrants cités par ce chapitre pour la phase de génération — reproduirait exactement le biais que ce chapitre décrit.
- (d) L'introduction définit le risque opérationnel selon Bâle comme « le risque de perte résultant de processus internes, de personnes ou de systèmes inadéquats ou défaillants, ou d'événements externes », en précisant que « cette définition porte sur les causes du risque opérationnel — personnes, processus, systèmes, événements externes — non sur ses conséquences ». Montrer que la taxonomie PPSE d'ORX présentée par ce chapitre — « personnes, processus, systèmes, événements externes », « issu[e] de la définition de Bâle » — est très précisément une reprise littérale des quatre causes énumérées par la définition de l'introduction. Le chapitre 1 rappelle enfin que le « top-dix » des risques, tel que défini par ce chapitre comme « rapportée au moins trimestriellement au comité exécutif », doit s'inscrire dans une pyramide de comités où « le comité groupe de risque opérationnel consolide l'information vers le comité de direction et le comité risques du conseil ». À quel niveau précis de cette pyramide de comités le top-dix de ce chapitre devrait-il être élaboré avant transmission au comité exécutif, et pourquoi ce niveau intermédiaire, plutôt que les comités locaux à la base ou le comité risques du conseil au sommet, est-il le mieux placé pour cette synthèse ?

3 Applications en sciences économiques

Exercice 5 — Génération et sélection de scénarios, chiffrée

Une banque organise un atelier annuel de génération de scénarios, nourri par les quatre intrants cités par le cours. La liste brute obtenue est de 34 scénarios issus de l'analyse des pertes internes, 28 issus des bases de pertes externes consortiales, 22 issus des résultats de RCSA, et 16 issus des indicateurs de risque et des problèmes d'audit.

- Calculer le nombre total de scénarios de la liste brute, ainsi que la part (en %) de chacun des quatre intrants dans ce total.
- Le comité des risques applique la phase de sélection et retient une liste finale de 19 scénarios pour ce groupe bancaire international. Calculer le nombre de scénarios éliminés lors de la sélection, le taux de réduction (en %) par rapport à la liste brute, et la part (en %) que représente la liste finale dans la liste brute. Cette liste finale de 19 scénarios est-elle compatible avec la fourchette « 15 à 20 scénarios pour un établissement de taille moyenne » donnée par le cours, sachant qu'il s'agit ici d'un groupe international pour lequel le cours autorise « jusqu'à 50 » scénarios?
- Une première classification de la liste finale de 19 scénarios par cause (interne ou externe), réalisée sans vigilance particulière, aboutit à 14 scénarios de cause externe et 5 de cause interne. Calculer la part (en %) de chaque catégorie. Après relecture critique à la lumière du biais de focalisation excessive sur les causes externes, le comité reclasse la liste et aboutit à 10 scénarios de cause externe et 9 de cause interne. Calculer la nouvelle part (en %) de chaque catégorie, ainsi que la variation, en points de pourcentage, de la part des scénarios de cause externe entre les deux classifications.
- Le registre de risques de la banque comptait, en 2019, 2 scénarios liés au risque pandémique sur une liste brute de 95 scénarios générés cette année-là ; en 2021, il en comptait 9 sur une liste brute de 105 scénarios. Calculer la part (en %) des scénarios pandémiques dans chacune des deux listes, l'écart en points de pourcentage entre les deux années, et le facteur multiplicatif par lequel cette part a été multipliée entre 2019 et 2021. Ce résultat illustre-t-il le biais de myopie décrit par le cours?

Exercice 6 — Registre des risques, top-cinq et couverture par les contrôles, chiffrée

Une banque construit un registre de risque opérationnel de 12 risques. Chaque risque est rattaché à l'une des quatre catégories de causes PPSE (personnes, processus, systèmes, événements externes), reçoit un score de probabilité P et un score d'impact I (chacun sur une échelle de 1 à 5), dont le produit $P \times I$ constitue le score de risque, et se voit assigner un type de contrôle principal parmi les quatre catégories du cours (préventif, détectif, correctif, directif) :

Risque	Cause PPSE	P	I	Score $P \times I$	Contrôle principal
1	Personnes	3	4	—	Correctif
2	Processus	4	3	—	Détectif
3	Systèmes	2	5	—	Détectif
4	Externes	1	5	—	Directif
5	Personnes	2	2	—	Préventif
6	Processus	5	4	—	Directif
7	Systèmes	3	3	—	Préventif
8	Externes	4	4	—	Détectif
9	Personnes	1	1	—	Préventif
10	Processus	3	2	—	Préventif
11	Systèmes	4	5	—	Correctif
12	Externes	2	3	—	Préventif

- Calculer le score $P \times I$ de chacun des 12 risques ainsi que le score total du registre, puis classer les risques par score décroissant et identifier les cinq risques du « top-cinq » (l'analogue, à l'échelle de ce registre restreint, du « top-dix » défini par le cours comme « la synthèse des combinaisons

de probabilité et d'impact les plus significatives »). Quelle part (en %) du score total du registre ce top-cinq concentre-t-il ?

- (b) Calculer la part (en %) de chacune des quatre catégories PPSE dans le *nombre* de risques du registre, puis la part (en %) de chacune dans le score total (pondéré par $P \times I$). Ces deux répartitions sont-elles identiques ? Que révèle un éventuel écart entre elles quant à la capacité du seul dénombrement des risques par cause à refléter la répartition réelle de l'exposition ?
- (c) Calculer un indice de concentration simple — la somme des carrés des parts (exprimées en fraction, non en pourcentage) — pour la répartition par *nombre* de risques d'une part, et pour la répartition par *score* d'autre part. Sachant qu'un tel indice vaut 1 en cas de concentration totale sur une seule catégorie et $1/4 = 0,25$ en cas de répartition parfaitement égale entre les quatre catégories PPSE, que révèle la comparaison des deux indices obtenus quant à la différence entre diversification apparente (par le compte) et diversification réelle (par l'exposition) des causes de risque de ce registre ?
- (d) Calculer, parmi les 12 risques du registre, la part (en %) de chaque type de contrôle principal (préventif, détectif, correctif, directif). Calculer ensuite cette même répartition (en %), mais restreinte aux cinq risques du top-cinq identifié au (a). Le cours définit les contrôles préventifs comme ceux qui « réduisent la probabilité en agissant sur les causes ». Que révèle la comparaison entre la part des contrôles préventifs dans l'ensemble du registre et leur part parmi les seuls risques du top-cinq, quant à l'adéquation de la couverture par les contrôles des risques les plus significatifs de ce registre ?